

Penetration Testing Agreement

Table of Contents

1. Introduction & Purpose
 2. Scope of Work (SOW)
 3. Objectives & Methodology
 4. Deliverables & Timelines
 5. Client Responsibilities
 6. Rules of Engagement (ROE)
 7. Data Protection
 8. Confidentiality
 9. Intellectual Property
 10. Fees & Payment
 11. Liability & Warranty
 12. Indemnity & Insurance
 13. Termination
 14. Change Control
 15. Governing Law
 16. Acceptance & Signatures
- Appendix A – Scoping Form (Tables)
- Appendix B – Rules of Engagement (Tables)
- Appendix C – Escalation & Emergency Contact Matrix (Tables)
- Appendix D – Legal Authorization Letter

1. Introduction & Purpose

This Penetration Testing Agreement (“Agreement”) establishes the formal terms, responsibilities, and legally binding authorizations under which PentaSystems will conduct a structured and ethical security assessment of ParoCyber’s digital assets. The purpose of this engagement is to proactively evaluate the security posture of ParoCyber’s information systems by simulating realistic, controlled cyber-attacks that mirror techniques used by modern threat actors, including those categorized under MITRE ATT&CK, OWASP Top 10, and contemporary adversary tradecraft.

The penetration test will be carried out in accordance with internationally recognized security assessment frameworks, including but not limited to:

- NIST SP 800-115 (Technical Guide to Information Security Testing and Assessment)
- PTES (Penetration Testing Execution Standard)
- OWASP Testing Guide v4+
- OSSTMM (Open Source Security Testing Methodology Manual)
- ISO/IEC 27001:2022 Annex A Controls

The objective of this engagement is not only to identify vulnerabilities, misconfigurations, weak controls, and exploitable weaknesses, but also to demonstrate their potential impact through controlled exploitation. This includes assessing risks to confidentiality, integrity, and availability of Client systems, validating the effectiveness of existing security controls, and determining the ability of ParoCyber’s environment to withstand targeted cyberattacks.

The results of this penetration test will support ParoCyber in:

- Strengthening defensive security controls
- Reducing the likelihood and impact of security breaches
- Meeting regulatory, audit, and compliance requirements
- Improving incident response readiness
- Enhancing overall cybersecurity maturity

Furthermore, this Agreement ensures that all testing activities are conducted lawfully, responsibly, and with explicit authorization from ParoCyber to prevent unintended operational disruption, data exposure, or legal liability. The Pentester will operate within clearly defined boundaries and Rules of Engagement (ROE), ensuring that testing is performed with precision, discretion, and due care.

The ultimate purpose of this engagement is to provide ParoCyber with a comprehensive, evidence-based understanding of its current security posture and actionable recommendations to remediate identified risks, thereby supporting the organization's strategic cybersecurity objectives.

2. Scope of Work (SOW)

This Scope of Work defines the boundaries, depth, and nature of the penetration testing services to be performed by the Pentester for ParoCyber. All testing activities shall strictly adhere to the systems, assets, and conditions explicitly authorized within this Agreement and its Appendices.

2.1 Objectives of the Engagement

The primary objectives of this penetration testing engagement are to:

- Identify vulnerabilities in ParoCyber's systems, networks, applications, and supporting environments.
- Assess the effectiveness of existing security controls and configurations.
- Simulate real-world cyberattacks using controlled and ethical exploitation techniques.
- Evaluate risk impact on confidentiality, integrity, and availability of Client assets.
- Provide actionable mitigation guidance to improve ParoCyber's security posture.

2.2 In-Scope Assets & Environments

The following systems and components are considered in-scope for testing:

- External Infrastructure: Public-facing hosts, IP ranges, and internet-accessible services.

- Internal Infrastructure (if authorized): Internal networks reachable via VPN or onsite access.
- Web Applications: Web-based portals, APIs, admin interfaces, or SaaS applications owned by ParoCyber.
- Cloud Environments: Azure, AWS, Google Cloud, or other third-party platforms where ParoCyber holds administrative control.
- Mobile Applications (optional): If listed, including Android/iOS apps and backend services.
- Authentication Systems: Single Sign-On (SSO), MFA, IAM solutions (as appropriate).

The precise list of in-scope targets is documented in Appendix A – Scoping Form, and no system will be tested unless explicitly listed and authorized.

2.3 Out-of-Scope Components

The following are strictly excluded unless separately approved in writing:

- Social Engineering Attacks: Phishing, vishing, tailgating, impersonation.
- Denial-of-Service (DoS) or Stress Testing: Including volumetric, protocol, or application-layer stress attacks.
- Physical Security Assessments: Facility access testing.
- Third-Party Systems: Assets not owned or contractually operated by ParoCyber.
- Production-critical systems where availability disruption cannot be tolerated.
- Any system not explicitly listed in Appendix A.

These exclusions ensure compliance with legal, operational, and safety requirements.

2.4 Testing Approach & Depth

Testing will be conducted using one of the following approaches, as designated in Appendix A:

2.4.1 Black-Box Testing

The Pentester receives no internal information or credentials. The assessment simulates an external attacker with minimal prior knowledge.

2.4.2 Grey-Box Testing

Partial knowledge and limited credentials are provided. This approach balances realism with depth and efficiency.

2.4.3 White-Box Testing

Full access to system documentation, architecture diagrams, and privileged test accounts is provided. This enables a comprehensive evaluation of internal security.

2.5 Activities Included in the Scope

The Pentester will perform the following activities:

- Asset Discovery & Reconnaissance
- OSINT collection, DNS enumeration, network scanning
- Vulnerability Identification
- Configuration and permission analysis
- Exploitation
- Controlled exploitation to validate vulnerabilities
- Privilege escalation attempts
- Lateral movement (if authorized)
- Post-Exploitation Assessment
- Assessing data exposure, system integrity, and potential attacker persistence
- Reporting
- Technical vulnerability matrix
- CVSS v3.1 severity scoring

- Executive summary
- Remediation recommendations
- Retesting & Validation (if included)
- One cycle of retesting remediated vulnerabilities (within 90 days)

2.6 Limitations and Boundaries

To prevent operational disruption:

- Testing will be conducted only during approved windows.
- No destructive or high-impact payloads will be executed without explicit authorization.
- Pentester will not access or manipulate Client data beyond what is required for proof-of-concept validation.
- Activities must comply with all applicable laws and industry ethics standards.

2.7 Deliverables

- The following deliverables will be produced as part of this SOW:
- Comprehensive Penetration Test Report
- Executive Summary Document
- Evidence Package (screenshots, logs)
- Priority Remediation Plan
- Formal Findings Presentation
- Optional Retest Report (if retesting requested)

3. Objectives & Methodology

This section outlines the overall purpose, strategic goals, and detailed methodology to be used during the penetration testing engagement. All testing activities will be executed in accordance with internationally recognized standards and ethical guidelines to ensure accuracy, safety, and legal compliance.

3.1 Core Objectives of the Engagement

The primary objectives of the penetration test are to:

1. Identify Security Vulnerabilities

Detect weaknesses in systems, networks, cloud environments, applications, and authentication mechanisms that could be exploited by threat actors.

2. Assess Real-World Exploitability

Demonstrate the practical impact of discovered vulnerabilities through controlled exploitation, highlighting risks to confidentiality, integrity, and availability.

3. Evaluate Security Control Effectiveness

Determine whether existing technical and administrative controls are properly implemented and capable of preventing, detecting, and responding to attacks.

4. Measure Cyber-Resilience

Assess the organization's ability to withstand targeted cyberattacks, including privilege escalation, lateral movement, and access to sensitive data.

5. Provide Strategic and Technical Remediation Guidance

Deliver actionable, prioritized recommendations aligned with modern security frameworks to support risk reduction and continuous improvement.

6. Support Regulatory, Audit, and Compliance Requirements

Assist ParoCyber in meeting obligations under ISO 27001, GDPR-equivalent data protection laws, PCI-DSS, and other relevant frameworks.

3.2 Testing Methodology Overview

The penetration test will follow a structured, multi-phase methodology derived from:

- NIST SP 800-115
- Penetration Testing Execution Standard (PTES)
- OWASP Testing Guide v4+
- MITRE ATT&CK Framework
- OSSTMM

This ensures that testing is systematic, thorough, and aligned with globally accepted best practices.

3.3 Detailed Methodology Phases

Phase 1: Reconnaissance (Information Gathering)

Objective: Identify public and internal information relevant to the target environment.

Activities include:

- Passive information gathering (OSINT, WHOIS, DNS, metadata extraction)
- Active enumeration (port scanning, service detection, banner grabbing)
- Cloud platform discovery and misconfiguration analysis

Outcome: A detailed understanding of the attack surface and potential entry points.

Phase 2: Vulnerability Identification

Objective: Detect security weaknesses across all in-scope systems.

Activities include

- Automated vulnerability scanning using commercial and open-source tools
- Manual verification to eliminate false positives
- Analysis of outdated software, weak encryption, insecure configurations, and flawed authentication mechanisms

Outcome: A validated vulnerability stack prioritized for exploitation testing.

Phase 3: Exploitation

Objective: Safely exploit validated vulnerabilities to determine real-world impact.

Activities include:

- Controlled exploitation of identified weaknesses
- Credential harvesting and authentication bypass techniques
- Privilege escalation on compromised systems
- Lateral movement across network segments (if authorized)

Restrictions:

- No destructive payloads
- No data corruption
- No service interruption without explicit written approval

Outcome: Evidence-supported demonstration of risk and potential attacker pathways.

Phase 4: Post-Exploitation

Objective: Assess the depth of compromise and potential data exposure.

Activities include:

- Access verification to sensitive information
- Persistence testing (if authorized)
- Segmentation and privilege boundary evaluation
- Identification of high-risk misconfigurations enabling continued attacker presence

Outcome: A realistic assessment of the potential damage of a successful attack.

Phase 5: Reporting

Objective: Deliver comprehensive, clear, and actionable documentation of the results.

Reports include:

- Executive Summary (non-technical, business impact)
- Technical Findings Matrix
- CVSS v3.1 Severity Scoring
- Screenshots, logs, and proof-of-concept evidence
- Root cause analysis
- Detailed mitigation steps and best-practice recommendations

Outcome: A complete roadmap to reduce identified risks.

Phase 6: Retesting (If Applicable)

Objective: Validate remediation efforts.

Activities include:

- Re-executing original attack vectors
- Confirming patching or configuration fixes
- Updating findings accordingly

Outcome: A Retest Report confirming closure status of vulnerabilities.

3.4 Quality Assurance & Ethics

The Pentester commits to:

- Acting responsibly and legally at all times
- Minimizing impact to operational systems
- Maintaining strict confidentiality
- Using a combination of automated and expert manual techniques
- Ensuring testing is evidence-driven and verifiable

3.5 Tools, Frameworks, and Technologies

The Pentester may use—but is not limited to—the following categories of tools:

- Network and application scanners
- Malware-less exploitation frameworks
- Cloud security analysis tools
- Password auditing and MFA testing tools
- Custom scripts and proprietary testing utilities

Use of such tools adheres to safety controls and professional standards.

4. Deliverables & Timelines

This section defines the formal outputs that the Pentester will provide to ParoCyber as part of the engagement, along with the expected delivery timelines. All deliverables shall meet industry standards for clarity, accuracy, and actionable value.

4.1 Overview of Deliverables

Upon completion of the penetration testing activities, the Pentester will produce the following deliverables:

4.2. Deliverable 1: Penetration Testing Execution

A full technical security assessment conducted according to the agreed methodology and scope, including:

- End-to-end execution of reconnaissance, vulnerability identification, exploitation, and post-exploitation phases
- Detailed documentation of all tests performed
- Live tracking of critical findings (if applicable)
- Strict adherence to Rules of Engagement and authorized test windows

Format: Conducted in-lab, onsite, or remotely, depending on scope.

4.3. Deliverable 2: Comprehensive Penetration Test Report

A professionally structured, evidence-based, and actionable report consisting of:

A. Executive Summary (Non-Technical)

Designed for executive leadership and decision-makers. Includes:

- Overall risk posture
- High-level findings
- Likelihood vs. impact analysis
- Key business risks

- Strategic recommendations
- Maturity and resilience assessment
- High-level attack narratives (if applicable)

B. Technical Findings Section

Includes a detailed breakdown of every validated vulnerability:

- Clear description of each finding
- Affected systems and attack vectors
- CVSS v3.1 severity score
- Exploitability assessment
- Business impact analysis
- Root cause analysis
- Evidence (screenshots, logs, payloads)
- References to security standards (NIST, OWASP, CIS, ISO 27001)

C. Remediation Recommendations

Each finding is paired with targeted, actionable remediation guidance, including:

- Immediate containment measures
- Long-term mitigation steps
- Configuration best practices
- References to vendor and industry guidelines

D. Visualizations & Summary Charts (Optional, based on engagement size)

- Risk heat maps
- CVSS severity distribution charts
- Vulnerability timeline

- Attack flow diagrams
- Systemic weakness analysis

Format: Delivered as a PDF and an optional DOCX version.

4.4 Deliverable 3: Evidence Package

A structured archive containing:

- Screenshots, logs, and proof-of-concept captures
- Session notes and timestamps
- Payloads used (non-destructive only)
- Tool output excerpts (where legally permissible)
- Sensitive information will be redacted where possible.

Format: Encrypted ZIP archive with password delivered separately.

4.5 Deliverable 4: Executive or Technical Presentation

A formal presentation (remote or onsite) delivered to ParoCyber stakeholders summarizing:

- Testing scope & objectives
- Attack paths and key exploitation steps
- Demonstrated impacts
- Top critical vulnerabilities
- Roadmap for remediation
- Improvement recommendations

Duration: 45–90 minutes based on complexity and audience.

4.6 Deliverable 5: Retest & Validation Report (If Included)

If ParoCyber requests remediation validation within the engagement period:

- Re-evaluation of all previously identified vulnerabilities
- Verification that fixes have been implemented correctly
- Updated status (Resolved / Partially Resolved / Not Resolved)
- Updated risk scoring where applicable

Retest Window: One retest within 90 days of initial report delivery (unless otherwise contracted).

4.7 Delivery Timelines

Timelines depend on environment size and complexity. Standard delivery expectations are:

Testing Duration

- Small Environment: 3–5 business days
- Medium Environment: 7–10 business days
- Large/Enterprise Environment: 12–20 business days

Reporting Timeline

- Initial Draft Report: Within 3 business days after testing completion
- Final Report: Within 5 business days after Client feedback (if revisions needed)

Presentation Timeline

- Delivered within 5 business days of final report submission

Can be scheduled earlier on request

Retest Timeline

- Conducted within 10 business days of retest request

Retest Report delivered within 5 business days after retest execution

4.8 Delivery Method

All deliverables will be provided through secure channels:

- Encrypted email attachments
- Secure file transfer portals
- Password shared via separate communication method
- Optional on-site handover (for sensitive environments)

4.9 Acceptance Criteria

A deliverable will be considered accepted when:

- It has been submitted to ParoCyber according to agreed timelines
- It meets the requirements outlined in this SOW
- Any required revisions under the scope of this contract have been addressed
- ParoCyber provides written or implied acceptance within 5 business days of receipt

Failure to raise objections within the acceptance period constitutes acceptance.

5. Client Responsibilities and Authorizations.

To ensure that the penetration testing engagement is conducted safely, lawfully, and effectively, ParoCyber ("Client") agrees to fulfill the following responsibilities.

5.1 Legal Authorization

1. The Client warrants that it owns or has full legal permission to authorize testing of all systems listed in Appendix A.
2. The Client shall sign the Authorization to Test (Appendix D) before testing begins.
3. The Client is responsible for obtaining any required third-party or cloud-provider approvals.
4. The Client indemnifies the Pentester against claims arising from incorrect or incomplete authorization.

5.2 Pre-Engagement Preparation

The Client shall:

- Complete the Scoping Form (Appendix A) with accurate asset details.
- Review and approve the Rules of Engagement (ROE) in Appendix B.
- Provide necessary accounts, MFA tokens, or VPN access for Grey/White-box testing.
- Whitelist Pentester IP addresses where applicable.
- Inform the Pentester of any systems requiring special caution or no-impact testing.

5.3 Data Protection & Backups

- The Client must ensure all critical systems are backed up prior to testing.
- The Client must identify systems containing sensitive or regulated data.
- The Pentester will avoid accessing sensitive data unless required for evidence and will operate under applicable data protection laws.

5.4 Internal Coordination

The Client must notify internal teams, including SOC, NOC, IT support, and incident response, of the authorized testing window to avoid false alarms or unintended disruptions.

The Client shall designate:

- One primary technical point-of-contact, and
- One secondary contact,

who will be available for approvals, clarifications, and emergency communications during testing.

5.5 Responsibilities During Testing

The Client agrees to:

- Respond promptly to Pentester inquiries.
- Notify the Pentester immediately of system instability or performance issues.
- Avoid unplanned system changes or updates during the testing window unless coordinated.
- Maintain open communication channels for escalation.

5.6 Emergency Stop

The Client may halt testing at any time for any reason.

The Pentester will immediately cease all activity upon receiving a stop request.

5.7 Post-Engagement Responsibilities

After the assessment, the Client shall:

- Review deliverables within the acceptance period.
- Implement recommended remediations as appropriate.
- Request retesting (if included or contracted).
- Disable or remove test accounts provided for the engagement.

5.8 Acknowledgment of Controlled Risk

The Client understands that penetration testing involves controlled interaction with production or test systems and may carry minimal operational risk. The Pentester will take all reasonable steps to avoid disruption.

6. Rules of Engagement (ROE)

The following Rules of Engagement govern how all penetration testing activities will be conducted to ensure safety, legality, and minimal operational impact.

6.1 Authorized Testing Window

- All testing will occur only during the dates and times approved in Appendix A.
- Any testing outside of this window requires written authorization.

6.2 Permitted Activities

The Pentester may perform:

- Reconnaissance, enumeration, and vulnerability analysis
- Non-destructive exploitation to validate vulnerabilities
- Privilege escalation and limited lateral movement (if authorized)
- Evidence collection using safe, minimally invasive methods

6.3 Prohibited Activities

Unless explicitly approved in writing, the Pentester will NOT perform:

- Denial-of-Service (DoS) or stress testing
- Social engineering (phishing, vishing, impersonation)
- Physical security testing
- Any action that risks data corruption or system downtime

6.4 Safety Controls

- No destructive payloads or malware will be deployed.
- The Pentester will minimize operational impact and avoid unnecessary access to sensitive data.
- Critical vulnerabilities discovered will be reported to the Client immediately.

6.5 Emergency Stop Protocol

- The Client may suspend testing at any time for any reason.
- The Pentester will cease all activity immediately upon receiving a stop request.

6.6 Logging & Documentation

- All significant actions will be logged with timestamps.
- Evidence will be collected in the smallest quantity needed to demonstrate findings.
- All logs remain confidential and will be included in the final evidence package.

6.7 Communication

- The Pentester will maintain regular communication with the Client's designated point-of-contact.
- Escalation will follow the matrix outlined in Appendix C.

7. Data Protection

This section outlines how all personal, confidential, and sensitive data encountered during testing will be handled.

7.1 Data Handling Principles

- The Pentester will only access data strictly necessary to validate vulnerabilities.
- Sensitive or regulated data will be avoided whenever possible and immediately reported if unintentionally accessed.

7.2 Roles Under Data Protection Laws

- Client: Acts as the Data Controller (responsible for all personal data).
- Pentester: Acts as a Data Processor (handles data only for testing and reporting).

7.3 Data Collection & Retention

- Only minimal evidence will be collected (screenshots, logs).
- Sensitive information will be redacted wherever possible.
- All collected data will be securely stored and deleted within 30 days of engagement completion unless legally required to retain.

7.4 Confidentiality & Security

- All data handled during testing is confidential.
- The Pentester will use encrypted storage and secure communication channels.
- No data will be shared with third parties without written Client consent.

7.5 Compliance

All data protection activities will comply with applicable privacy regulations including GDPR-equivalent standards, National Data Protection Act, and industry best practices.

8. Confidentiality

This section outlines the confidentiality obligations of both the Client and the Pentester.

8.1 Mutual Confidentiality

Both parties agree to treat all information exchanged during this engagement—including system details, test results, credentials, logs, and final reports—as strictly confidential.

8.2 Protection of Sensitive Information

- The Pentester will safeguard all evidence, findings, and collected data using secure storage and encrypted channels.
- The Client shall protect all reports and materials shared by the Pentester from unauthorized access or distribution.

8.3 Restrictions on Disclosure

Neither party may disclose confidential information to third parties without express written consent, except where required by law, regulatory authorities, or legal proceedings.

8.4 Retention & Destruction

- The Pentester will retain logs and evidence only as long as necessary to complete the engagement or as legally required.
- All sensitive data will be securely deleted within 30 days after project completion unless otherwise agreed.

8.5 Use of Findings

- The Client may use the results internally for remediation, audit, or governance purposes.
- The Pentester may not publish, present, or reference findings externally without prior written permission.

9. Intellectual Property

This section defines ownership rights for tools, reports, and materials used or produced during the engagement.

9.1 Pentester Intellectual Property

- All tools, scripts, methodologies, frameworks, and proprietary techniques used by the Pentester remain the exclusive intellectual property of the Pentester.
- The Client is not entitled to receive or reverse-engineer proprietary tools or source code.

9.2 Client Ownership of Deliverables

- All final deliverables—including the penetration test report, executive summary, evidence package, and presentation—become the property of the Client upon full payment.

- The Client receives an unrestricted internal-use license to store, reproduce, and utilize these deliverables for security, audit, and compliance purposes.

9.3 Limited License to Use Pentester Materials

Where Pentester-developed templates, graphics, or analysis models are embedded within the report, the Client receives a non-transferable license to use them internally but not to resell or redistribute them.

9.4 Restrictions on Distribution

- The Client may not share deliverables externally unless necessary for audit, compliance, or regulatory review.
- External sharing with partners, service providers, or third parties requires written Pentester approval to avoid misinterpretation or misuse.

9.5 Improvements and Custom Work

Any custom testing artifacts or scripts developed specifically for this engagement remain the Pentester's property but may be referenced in the deliverables for transparency.

10. Fees & Payment

All fees for the penetration testing services will be defined in the formal quotation or Statement of Work, with payment structured as 50% due upon acceptance of this Agreement and 50% due upon delivery of the final penetration test report. Additional services requested outside the agreed scope such as extended testing, additional retesting cycles, or consulting support—will be billed separately at the rates specified by the Pentester. All invoices are payable within the agreed payment terms, and failure to remit payment may delay deliverables or result in suspension of services. Any travel or extraordinary expenses incurred at the Client's request will be billed to the Client with prior approval.

11. Liability & Warranty

11.1 Standard of Care

The Pentester warrants that all services will be performed with reasonable skill, professional competence, and due care consistent with industry best practices for ethical penetration testing. While the Pentester will make every effort to identify vulnerabilities, the Client acknowledges that no penetration test can guarantee the discovery of all security weaknesses or prevent all future attacks.

11.2 Limitation of Liability

To the maximum extent permitted by law, the Pentester's total liability arising out of or related to this Agreement—whether in contract, tort, negligence, or otherwise—shall not exceed the total amount of fees paid by the Client for the engagement. In no event shall the Pentester be liable for any indirect, incidental, consequential, punitive, or special damages, including but not limited to lost profits, business interruption, loss of data, reputational harm, or costs associated with system recovery or operational downtime.

11.3 Exclusions

The Pentester shall not be liable for:

- Issues arising from the Client's failure to implement recommended remediations
- Unstable, misconfigured, or unsupported systems that react unpredictably to safe testing procedures
- Damage caused by unapproved changes made by the Client during the engagement
- Third-party service outages or disruptions outside the Pentester's control

11.4 Client Assumption of Operational Risk

The Client acknowledges that penetration testing involves controlled interaction with live systems and may carry inherent minimal risk of performance degradation or unexpected behavior. The Client accepts this risk and agrees that appropriate safeguards—such as backups, monitoring, and change control—are its sole responsibility.

11.5 Force Majeure

Neither party shall be liable for failure to perform obligations due to events beyond reasonable control, including natural disasters, power outages, cyber incidents, or other unforeseen disruptions.

12. Indemnity & Insurance

12.1 Client Indemnification

The Client agrees to indemnify, defend, and hold harmless the Pentester from any claims, damages, liabilities, losses, or expenses (including reasonable legal fees) arising from:

- The Client's failure to properly authorize testing on in-scope systems
- Misrepresentation of ownership or testing rights
- The Client's violation of applicable laws, regulations, or third-party agreements
- Any damages resulting from the Client's failure to follow remediation recommendations or misuse of testing results.

This indemnification does not apply to claims resulting from the Pentester's proven gross negligence or intentional misconduct.

12.2 Pentester Indemnification

The Pentester will indemnify the Client against claims arising solely from the Pentester's intentional misconduct or willful violation of law during the performance of services. Liability does not extend beyond the limitations described in Section 11.

12.3 Insurance Requirements

The Pentester shall maintain appropriate professional liability and cyber liability insurance coverage throughout the duration of this engagement. Such coverage will include errors and omissions, data breach liability, and legal defense costs. Proof of insurance may be provided to the Client upon request.

12.4 No Third-Party Beneficiaries

This section applies only to the parties listed in this Agreement and creates no rights for any third party, subcontractor, or external entity.

13. Termination

13.1 Termination for Cause

Either party may terminate this Agreement immediately upon written notice if the other party materially breaches any provision of the Agreement and fails to remedy such breach within five (5) business days of receiving written notice.

13.2 Termination for Convenience

The Client may terminate the engagement at any time for any reason by providing written notice to the Pentester. In such cases, the Client remains responsible for payment of all work completed up to the date of termination.

13.3 Suspension of Services

The Pentester reserves the right to suspend testing activities if:

The Client fails to provide required access, authorization, or payment;

Continuing the test poses a safety, legal, or operational risk;

The Client issues an emergency stop request.

Testing will resume only after the issue has been resolved in writing.

13.4 Effect of Termination

Upon termination:

The Pentester will cease all testing and return or securely destroy all Client data in accordance with Section 8.

The Client will pay for completed services and deliverables up to the termination date.

Any partially completed reports will be provided “as-is” at the Client’s request.

13.5 Survival of Terms

Confidentiality, liability limitations, intellectual property rights, payment obligations, and data protection requirements shall survive termination of this Agreement.

14. Change Control

14.1 Requirement for Written Changes

Any modifications to the scope, timelines, deliverables, methodology, or terms of this Agreement must be documented and approved through a written Change Order signed by both parties prior to implementation. Verbal or informal requests shall not be considered valid or binding.

14.2 Impact Assessment

Upon receiving a request for change, the Pentester will evaluate and communicate to the Client any resulting adjustments to:

- Fees or billing structure
- Project timeline
- Required resources or access
- Testing methodology or approach
- Associated risks or constraints

No change will be implemented until both parties agree in writing to the revised conditions.

14.3 Changes Initiated by Pentester

If the Pentester identifies a necessary change due to safety concerns, unexpected technical limitations, or newly discovered legal obligations, the Pentester will issue a written recommendation for Client review. Testing activities may be paused until the change is approved.

14.4 Emergency Adjustments

In urgent situations (e.g., system instability, emerging risks), temporary procedural adjustments may be made at the Pentester's discretion to prevent harm. These must be documented and communicated to the Client within 24 hours.

14.5 Record Keeping

All Change Orders and associated correspondence shall be retained as part of the official project record and will form part of this Agreement.

15. Governing Law

15.1 Applicable Law

This Agreement shall be governed by and interpreted in accordance with the laws of the jurisdiction selected by the Client, without regard to conflict-of-law principles. The chosen jurisdiction must be specified in writing within the final executed Agreement.

15.2 Dispute Resolution

In the event of a dispute arising from or relating to this Agreement, the parties agree to first attempt to resolve the matter through good-faith negotiation. If negotiation fails, the dispute shall be escalated to mediation or arbitration, unless prohibited by applicable law, prior to pursuing formal legal action.

15.3 Venue

Any legal proceedings, if required, shall be brought exclusively before courts within the designated governing jurisdiction, and both parties consent to the personal and subject matter jurisdiction of those courts.

15.4 Compliance With Local Laws

Both parties agree to comply with all applicable local, national, and international laws and regulations governing cybersecurity, data protection, and lawful interception during the execution of this Agreement.

16. Acceptance & Signatures

By signing below, both parties acknowledge that they have read, understood, and agree to all terms and conditions set forth in this Penetration Testing Agreement, including all attached Appendices, Rules of Engagement, and authorized scope documentation. The signatures below constitute full and binding acceptance of this Agreement and grant the Pentester legal authorization to conduct all testing activities described herein.

This Agreement becomes effective as of the Effective Date indicated below and remains valid until all deliverables are completed or until terminated in accordance with Section 13.

16.1 Client (ParoCyber)

Authorized Representative: _____

Title: _____

Organization: ParoCyber

Signature: _____

Date: _____

16.2 PentaSystems (Independent Consultant)

Name: _____

Title: Independent Penetration Tester

Signature: _____

Date: _____

16.3 Optional Witness

Name: _____

Signature: _____

Date: _____

Appendix A – Scoping Form

Authorized systems to be tested:

IP Ranges	_____
Domains	_____
Web Applications	_____
APIs	_____
Cloud Assets	_____

Testing Mode:

Black-Box	☐ Selected
Grey-Box	☐ Selected
White-Box	☐ Selected

Testing Window:

Start Date/Time	_____
End Date/Time	_____

Appendix B – Rules of Engagement (ROE)

Destructive Testing	Not permitted unless explicitly authorized
Social Engineering	Only allowed with written permission
Allowed Hours	_____
Logging Requirements	Pentester logs all activity with timestamps
Emergency Stop	Pentester must halt when instructed
Reporting Timeline	Critical issues reported within 1 hour

Appendix C – Escalation & Emergency Contacts

Client Contacts:

Security Lead	_____
SOC Contact	_____
Incident Response Lead	_____
24/7 Hotline	_____

Pentester Contacts:

Lead Tester	_____
Backup Tester	_____
Emergency Contact	_____

Appendix D – Legal Authorization Letter

This letter officially authorizes the penetration testing activities described in the Pentesting Agreement.

I, _____ (authorized representative of ParoCyber),
grant full legal permission for [Pentester Name] to conduct penetration testing
against all systems listed in Appendix A.

Signature: _____

Date: _____